Regardless of which technique you choose to validate the origin, the steps of the validation are the same:

1. Grab the value from the Origin header.
2. Validate the origin value using your chosen technique.
3. If the origin is valid, set the Access-Control-Allow-Origin header.

6.3.3 CORS and proxy servers

One side effect of validating origins against a whitelist is that the value of the Access-Control-Allow-Origin header can vary between requests. For example, a request from the origin http://localhost:1111 will return the header `Access-Control-Allow-Origin: http://localhost:1111`, but a request from http://localhost:2222 to the same server will return the header `Access-Control-Allow-Origin: http://localhost:2222`. These different response headers from the same servers can sometimes cause caching issues. If your server can return different Access-Control-Allow-Origin headers to different clients, you should also set the Vary HTTP response header to `Origin`, like so:

```
Vary: Origin
```

Without the Vary header, proxy servers may cache responses for one client and send them as responses to a different client. This issue is notoriously difficult to debug, because it may not be reproducible from clients who aren't behind the same proxy servers.

A *proxy server* is a server that sits between the client and the destination server. The proxy server forwards the request from the client to the server. Along the way, it may also provide additional functionality, such as caching data to speed up response time. Figure 6.5 shows two separate requests passing through a proxy server; the first request hits the destination server, while the second request is cached.

It's this caching functionality that is relevant to CORS. Proxy servers use some, but not all, of the HTTP request headers when deciding whether or not to cache a response. Because the Origin header is a fairly new HTTP header, not all proxy servers take the Origin header into account when deciding whether to cache a response.

Suppose it's Monday morning and coworkers Bob and Alice are at work catching up on the highlights from yesterday's game. They both get the scores from ESPN, but

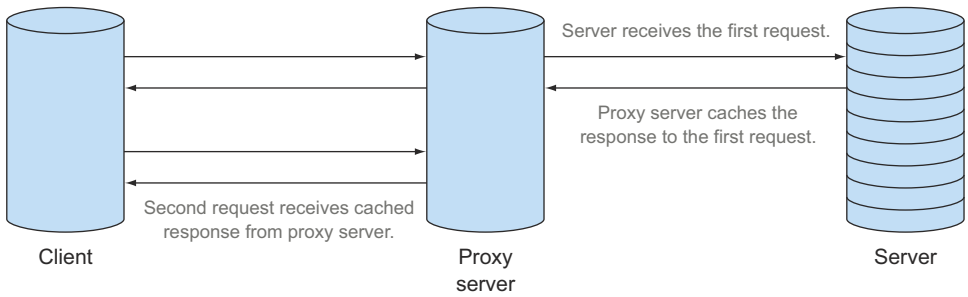


Figure 6.5 Example of a proxy server making two requests